

Incident Handler's Journal

G S Krishna Chandra | Google Cybersecurity Certificate — Course 6 (Incident Detection & Response)

This journal documents incidents, tools, and reflections from course activities related to incident detection and response. Each entry follows a consistent structure to record key details and lessons learned.

Entry 1 — Ransomware Attack on a Healthcare Clinic

Date: March 8, 2026	Entry: 1
Description	A small U.S. healthcare clinic experienced a ransomware attack on a Tuesday morning, which encrypted critical files including patient records and disrupted business operations. The attackers gained initial access through a phishing email containing a malicious attachment.
Tool(s) used	None (no cybersecurity tools were used in handling this incident as described in the scenario)
The 5 W's	Who: An organized group of unethical hackers known for targeting healthcare and transportation organizations caused the incident. What: Ransomware encrypted the clinic's critical files, including medical records, and a ransom note demanded payment in exchange for the decryption key. Employees lost access to systems and files needed to do their jobs, halting business operations. When: The incident occurred on a Tuesday morning at approximately 9:00 a.m. Where: The incident occurred on the clinic's internal computer network, affecting employee workstations and file systems. Why: The attackers gained access via a targeted phishing email containing a malicious attachment; once an employee downloaded it, malware was installed, allowing the attackers to deploy ransomware across the network.
Additional notes	This incident highlights how a single phishing email can lead to a complete operational shutdown, especially in healthcare where patient data access is time-critical. It raises the question of whether the clinic had email filtering or phishing awareness



training in place, and whether backups existed that could have avoided the need to consider paying the ransom.

Entry 2 — Packet Analysis with Wireshark

Date: March 8, 2026	Entry: 2
Description	As a security analyst, I used Wireshark to investigate a packet capture (.pcap) file containing traffic from a system browsing the website opensource.google.com . The goal was to identify the source and destination IP addresses involved, examine the protocols used to establish the connection, and inspect packet payloads for relevant information.
Tool(s) used	Wireshark — used to open the sample.pcap file, inspect frame/Ethernet/IP/TCP/UDP/DNS layers, and apply display filters (<code>ip.addr</code> , <code>ip.src</code> , <code>ip.dst</code> , <code>eth.addr</code> , <code>udp.port</code> , <code>tcp.port</code> , <code>tcp contains</code>)
The 5 W's	Who: A system on the network initiated the traffic — IP address 142.250.1.139 (a Google server) was the primary external host involved in the web browsing session under investigation. What: A user's system made a DNS query for opensource.google.com (resolved to 142.250.1.139), followed by ICMP echo requests and a TCP/HTTP web session on port 80 to retrieve the page content. When: The captured traffic represents a single web browsing session, with packet timestamps recorded in the .pcap file showing the sequence of DNS resolution, ICMP, and TCP/HTTP communication. Where: The traffic occurred between the local host's network interface and external Google servers, captured at the network boundary and saved as a local packet capture file for analysis. Why: This analysis was performed to practice identifying and filtering relevant network traffic — a core security analyst skill for investigating suspicious activity, verifying DNS resolution, and confirming the protocols and ports used during a connection.
Additional notes	This lab reinforced how display filters (<code>ip.addr</code> , <code>ip.src/dst</code> , <code>eth.addr</code> , <code>udp.port == 53</code> , <code>tcp.port == 80</code> , and <code>"tcp contains"</code>) dramatically narrow down large packet captures to relevant traffic. Drilling into the Frame, Ethernet II, IPv4, and TCP subtrees helped connect theory (OSI layers) to real packet data — for example, seeing the IPv4 header length (20 bytes, no options) and TTL (64, typical of Linux hosts) directly in a



captured packet. This is a foundational skill for incident investigation and traffic analysis in a SOC role.

Entry 3 — Network Traffic Capture with tcpdump

Date: March 8, 2026	Entry: 3
Description	As a network analyst, I used tcpdump on a Linux virtual machine to identify available network interfaces, capture live network traffic, save packet data to a .pcap file, and filter and inspect the captured data. This activity focused on command-line packet analysis as an alternative to GUI-based tools like Wireshark.
Tool(s) used	tcpdump — used with flags: -i (interface), -v (verbose), -c (packet count), -nn (disable name lookup), -w (write to file), -r (read from file), -X (hex/ASCII output), -D (list interfaces); ifconfig — used to identify network interfaces; curl — used to generate HTTP traffic for capture
The 5 W's	Who: The analyst (me) initiated the packet capture activity on a Linux virtual machine in a controlled lab environment. What: Live network traffic was captured on the eth0 interface using tcpdump, filtered to TCP port 80 (HTTP), saved to a capture.pcap file, and then read back and inspected — including hex/ASCII output to analyze packet payloads. When: During the lab session on June 16, 2026; the curl command to opensource.google.com was used to generate real-time HTTP traffic for capture. Where: On a Linux virtual machine (eth0 interface, IP 172.17.0.2) communicating with an external server (146.75.38.132) over TCP port 80. Why: To practice capturing and filtering network packet data from the command line — a critical skill for security analysts who need to investigate network traffic without a GUI-based tool available.
Additional notes	This lab reinforced the importance of using -nn in tcpdump to avoid DNS lookups during investigations — resolving names could alert threat actors or return inaccurate results. The -X flag was particularly useful for viewing hex/ASCII payload data, which is essential for malware and forensic analysis. Comparing this with the Wireshark lab (Entry 2) shows that both tools serve the same purpose but tcpdump is better suited for headless/remote Linux environments. Key command to remember: <code>sudo tcpdump -i eth0 -nn -c9 port 80 -w</code>



capture.pcap & runs a background capture filtered to HTTP traffic.

Entry 4 — Malware Analysis with VirusTotal and Pyramid of Pain

Date: March 9, 2026	Entry: 4
Description	As a Level 1 SOC analyst at a financial services company, I investigated an alert about a suspicious file downloaded by an employee via a password-protected email attachment. I created a SHA256 hash of the file and submitted it to VirusTotal to determine if it was malicious. I then identified multiple indicators of compromise (IoCs) associated with the file and documented them using the Pyramid of Pain framework.
Tool(s) used	VirusTotal — used to analyze the SHA256 file hash (54e6ea47eb04634d3e87fd7787e2136ccfbcc80ade34f246a12cf93bab527f6b) across the Detection, Details, Relations, and Behavior tabs to determine maliciousness and extract IoCs; Pyramid of Pain — used as the framework to categorize and document the identified IoCs by difficulty level
The 5 W's	Who: An unknown threat actor delivered the malware via a targeted phishing email to an employee of a financial services company. The file was flagged by multiple security vendors including CAPE Sandbox, Yomi Hunter, and DAS-Security Orcas. What: A malicious PE32 Windows executable (440 KB) was delivered as a password-protected email attachment. Once opened, it executed a payload, created unauthorized executable files, dropped /temp/mxresolver.exe, and made outbound connections to a malicious C2 domain (org.misecure.com) and IP address (209.25.140.91). When: The alert was triggered at 1:20 p.m. after the employee received the email at 1:11 p.m., downloaded and opened the file at 1:13 p.m., and unauthorized executables were created by 1:15 p.m. Where: The incident occurred on an employee's computer at a financial services company. The malware contacted external infrastructure including IP 209.25.140.91 and domain org.misecure.com. Why: The attacker used a social engineering technique — a password-protected attachment with the password included in the email — to bypass email security filters and trick the employee into opening a malicious file, executing the payload on the victim's system.

Additional notes

The Pyramid of Pain framework was helpful in understanding the relative value of each IoC to defenders. Hash values (MD5: 287d612e29b71c90aa54947313810a25) are easy for attackers to change but quick to block. IP addresses and domain names are harder to change but still rotatable. TTPs — such as T1566.001 (Spearphishing Attachment), T1059 (Command Interpreter), and T1204.002 (Malicious File Execution) — are the most valuable IoCs because blocking attacker behaviour at the TTP level forces them to significantly change how they operate. The password-protected attachment technique is a notable social engineering tactic worth flagging for employee awareness training.

Entry 5 — Phishing Alert Response and Playbook Escalation

Date: March 9, 2026	Entry: 5
Description	As a Level 1 SOC analyst, I followed the organization's Phishing Incident Response Playbook to investigate alert ticket A-2703 (SEVERITY: Medium). The phishing email contained a verified malicious attachment (bfsvc.exe). I evaluated the alert details, applied the 5 W's framework, and escalated the ticket to a Level 2 SOC analyst per playbook Step 3.2.
Tool(s) used	Phishing Incident Response Playbook (v1.0) — used to guide the investigation steps and determine escalation vs. closure; VirusTotal — previously used to confirm the SHA256 hash (54e6ea47eb04634d3e87fd7787e2136ccfbcc80ade34f246a12cf93bab527f6b) as malicious; Alert Ticket A-2703 — reviewed for sender details, email body, attachment, and severity
The 5 W's	Who: An unknown threat actor using the sender alias "Def Communications" and a suspicious .su domain (76tguyhh6tgftrt7tg.su) sent a targeted phishing email to the HR department of Inergy. What: A phishing email was sent with a malicious executable attachment (bfsvc.exe) disguised as a resume. The SHA256 hash of the file has been confirmed malicious via VirusTotal — it drops unauthorized executables and establishes C2 connections. When: The phishing email was sent on Wednesday, July 20, 2022 at 9:30 AM. The IDS alert (A-2703) was triggered shortly after the file was accessed. Where: The email was delivered to hr@inergy.com (IP: 176.157.125.93) at a financial services company. Why: The attacker used social engineering — impersonating a job applicant and using a password-protected attachment with the password in the email body — to bypass email security filters and trick the HR recipient into opening a malicious executable file.
Additional notes	This activity demonstrated how a phishing playbook ensures a structured, consistent response — reducing analyst decision fatigue and response time. Three red flags were immediately visible without any tools: (1) sender domain mismatch (.su is a Soviet Union legacy TLD, commonly abused by threat actors), (2) multiple grammatical errors in the email body and subject

line ("Egnieer", "writing for to"), and (3) password-protected executable attachment — a classic social engineering bypass. The decision to escalate (vs. close) came directly from playbook Step 3.2 after the file hash was confirmed malicious in the previous activity. This connects directly to Entry 4 in this journal.

Entry 6 — Post-Incident Review: Data Breach Final Report

Date: March 9, 2026	Entry: 6
Description	As part of onboarding at a mid-sized retail company, I reviewed an incident final report from the Post-incident Activity phase of the NIST Incident Response Lifecycle. The report covered a data breach affecting approximately 50,000 customers that occurred in December 2022. I analyzed the report across four goals: identifying what happened, when it happened, how the organization responded, and what recommendations were made to prevent recurrence.
Tool(s) used	Incident Final Report — reviewed as the primary document; Web server access logs — referenced in the report as the key evidence source used by the security team to identify the forced browsing attack pattern (sequential high-volume order access)
The 5 W's	Who: An unknown external attacker who discovered and exploited a vulnerability in the company's e-commerce web application, then attempted to extort the company for \$50,000 in cryptocurrency. What: A data theft incident in which the attacker used a forced browsing attack to access and exfiltrate PII and financial data from approximately 50,000 customer purchase confirmation pages by manipulating order numbers in the URL string. Estimated financial impact: \$100,000. When: The attacker first contacted the company on December 22, 2022. The security team was notified on December 28, 2022 when a second email with a data sample and increased demand was received. Investigation ran December 28–31, 2022. Where: The attack occurred on the company's e-commerce web application. The vulnerability existed in the URL structure of purchase confirmation pages, allowing unauthorized access to other customers' order data. Why: The e-commerce application lacked proper access controls — it did not verify that authenticated users could only access their own order confirmation pages. This allowed sequential enumeration of order numbers to expose other customers' data, a classic IDOR (Insecure Direct Object Reference) / forced browsing vulnerability.

Additional notes

A key lesson from this report: the first extortion email on December 22 was dismissed as spam, delaying the investigation by six days. This highlights the importance of employee training — all suspicious emails, especially those claiming data theft, should be escalated to the security team immediately regardless of how they appear. The final report is a valuable post-incident document because it closes the loop on the NIST IR Lifecycle: the investigation section identified the root cause (forced browsing / IDOR), the response section documented remediation steps (free identity protection for customers), and the recommendations section provided actionable preventive controls (URL allowlisting, authenticated access enforcement, routine vulnerability scans). This structured approach is what separates mature security programs from reactive ones.